REVUE DE PRESSE HEBDOMADAIRE

Software Compliance

L'essentiel de la conformité des logiciels embarqués dans les produits de défense

N° 4 – Mardi 27 octobre 2026

Revue de presse hebdomadaire, tous les mardis

Deux failles critiques de PHP, déjà exploitées, mettent à l'épreuve la déclaration des vulnérabilités du CRA ; LiteLLM a été piégé sur PyPI et des clés d'autorités de certification eMudhra sont compromises ; le Royaume-Uni annonce pour décembre la mise à jour de ses listes de contrôle ; Oracle publie la première mise à jour de JDK 21 sous licence OTN.

DANS CE NUMÉRO

SBOM et normes 1
Outils 2
Chaîne d'approvisionnement 2
Commerce international 3
France et UE 3
Licences 4
Glossaire 4
Agenda 4

À LA UNE

Failles de PHP, la déclaration du CRA à l'épreuve

À propos de deux failles critiques de PHP exploitées, les autorités européennes rappellent que les fabricants doivent déclarer les vulnérabilités activement exploitées depuis le 11 septembre 2026.



Failles critiques de PHP : le 21 octobre 2026, la Commission, l'ENISA, le CERT-EU, Europol et le réseau des CSIRT ont appelé à corriger deux failles de ce langage qui permettent d'exécuter du code à distance sans authentification, et rappelé que les fabricants doivent déclarer les vulnérabilités activement exploitées sur la plateforme unique du CRA ; le CERT-FR constate des tentatives d'exploitation.

La déclaration souligne que des produits peuvent être touchés même s'ils ne semblent pas utiliser PHP ; elle renvoie à un inventaire, publié sur GitHub par le centre national de cybersécurité néerlandais, des logiciels tiers qui l'intègrent. Les branches corrigées vont de la 8.2 à la 8.5 ; les branches 5.x, 7.x, 8.0 et 8.1 ne sont plus maintenues.

L'industriel doit rechercher PHP dans les SBOM de ses produits, interfaces d'administration comprises, et suivre les correctifs de ses fournisseurs. Une exploitation constatée dans l'un de ses produits déclencherait l'alerte précoce prévue par le CRA, puis la notification complète. Selon la foire aux questions de l'ENISA, la déclaration n'est pas rétroactive pour une exploitation connue avant le 11 septembre, mais elle s'impose dès que le fabricant en apprend une après cette date.

EN BREF

Plateforme unique du CRA : lancée par l'ENISA le 11 septembre 2026, elle reçoit les déclarations des fabricants.

Périmètre : les déclarations CRA visent aussi les produits déjà sur le marché avant le 11 septembre et se poursuivent après la fin du support.

SBOM, NORMES ET RÉFÉRENTIELS

L'ENISA publie un guide technique du SBOM ; CycloneDX 2.0 et les normes du CRA restent attendus.

ENISA : un guide technique pour adopter le SBOM

Guide SBOM de l'ENISA : publié le 22 octobre 2026, le *ENISA Technical Advisory for Software Bill of Materials* décrit l'architecture, le cycle de vie, les menaces et les mesures de sécurité d'un SBOM ; il tient compte des exigences du CRA mais reste non contraignant.



Le guide compare les deux formats dominants, CycloneDX et SPDX, et rapproche les champs exigés par la directive technique TR-03183 du BSI allemand de ceux des éléments minimaux de la CISA.

Parmi les mesures proposées : ne récupérer les dépendances que dans des registres authentifiés, vérifier l'intégrité et la provenance des générateurs de SBOM avant de les exécuter, associer cryptographiquement chaque SBOM au logiciel qu'il décrit et le conserver dans un dépôt inaltérable ou versionné. L'industriel peut confronter sa chaîne de production de SBOM à cette liste.

EN BREF

CycloneDX 2.0 : version attendue à l'automne 2026, ratification par Ecma en décembre ; le format s'étendrait aux modèles de menaces et à la provenance des composants physiques.

OUTILS ET SERVICES DE CONFORMITÉ

cdxgen corrige une faille critique de son mode serveur ; Dependency-Track et ORT publient de nouvelles versions.

cdxgen : faille critique du mode serveur corrigée, détection de PHP

cdxgen : le générateur de SBOM du projet CycloneDX corrige, à partir des versions 12.8.7 et 13.5, une faille critique de son mode serveur qui permettait à un client non authentifié de faire exécuter les scripts de construction du projet analysé ; de nouvelles règles d'audit signalent les deux failles de PHP.

Deux défauts se combinaient : le contournement de la liste des hôtes git autorisés et la possibilité, pour la requête, d'activer l'installation des dépendances, donc l'exécution des scripts de construction du projet cloné. Selon les notes de version, le mode sécurisé sans installation des dépendances n'exécute plus aucun code du projet analysé.

Une équipe qui expose cdxgen comme service, appelé par sa chaîne d'intégration, doit vérifier sa version et l'accès au service. Les nouvelles règles d'audit pourraient compléter la recherche de PHP dans les SBOM des produits. La version 13.5 ajoute aussi l'inventaire matériel (HBOM) des postes Windows.

Dependency-Track 5.2.1 et 4.14.6 : correctifs de validation, d'audit et d'accès

Dependency-Track 5.2.1 et 4.14.6 : publiées le 25 octobre 2026, ces versions correctives de la plateforme d'analyse de SBOM de l'OWASP corrigent un échec de validation de certains SBOM et retirent l'autorité de certification racine d'eMudhra de leur image conteneur ; la 5.2.1 corrige aussi un contrôle d'accès inopérant.

La 4.14.6 enregistre désormais dans la piste d'audit la suppression d'un constat lors d'une nouvelle analyse de violation ; jusqu'ici, cette décision n'y laissait pas de trace. La 5.2.1 met aussi à jour une trentaine de dépendances, et le projet demande de lire ses notes de mise à niveau avant d'installer la version 5.

Les équipes qui exploitent la branche 5 doivent mettre à jour leurs instances pour fermer le contrôle d'accès défaillant. Un historique d'audit incomplet pourrait compliquer la justification, devant un client ou une autorité, des décisions prises sur une vulnérabilité. Le retrait de l'autorité eMudhra fait suite à la compromission de clés de huit de ses autorités intermédiaires.

ORT 97.1 : règles sur les fragments de code et inventaire des actions GitHub

ORT 97.1 : publiée le 22 octobre 2026, la boîte à outils d'analyse des composants et des licences permet d'écrire des règles sur les correspondances de fragments de code (*snippets*) et inventorie par défaut les actions GitHub utilisées comme dépendances.

La nouvelle règle *SnippetFindingRule* permet d'écrire des politiques sur les correspondances de fragments de code relevées par les scanneurs, comme SCANOSS, dont l'intégration accepte de nouvelles options. Un fragment copié d'un projet tiers peut emporter les obligations de la licence de ce projet.

Les équipes qui utilisent ORT verront les actions GitHub apparaître dans leurs inventaires et devront décider de leur traitement dans les rapports. Cet inventaire pourrait aider à repérer une action compromise dans la chaîne de construction d'un produit.

EN BREF

Chainguard : images durcies livrées avec SBOM signé, mises à jour quotidiennes et délai de 7 jours pour les CVE critiques (promesse de l'éditeur).

Grype 0.121 : depuis le 19 octobre 2026, le scanneur d'Anchore tient compte de la date de fin de support publiée par les distributions.

SÉCURITÉ DE LA CHAÎNE D'APPROVISIONNEMENT

LiteLLM a été piégé sur PyPI et Docker, des clés d'autorités de certification eMudhra sont compromises, OVHcloud détaille la cause du piégeage de son CLI ; la CISA publie sa stratégie et l'OpenSSF un guide sur la correction des vulnérabilités avec l'IA.

LiteLLM 1.107 : une version piégée sur PyPI et Docker

LiteLLM : le 21 octobre 2026, une version 1.107 malveillante de cette bibliothèque Python d'accès aux modèles d'IA a été publiée sur PyPI pendant environ deux heures, et des images Docker piégées ont été servies ; le code volait des identifiants dès le démarrage de Python, même sans que LiteLLM soit chargé.

Les images Docker v1.107, latest, main-latest et main-stable ont été piégées un peu plus longtemps que le paquet, jusqu'à 14 h 20 UTC. Selon Help Net Security, l'attaquant a commencé à tester les identifiants AWS volés environ quatre heures et demie après leur exfiltration.

L'analyse publiée par l'éditeur le 23 octobre remonte à une clé maître publiée par erreur le 27 mai dans un dépôt public.

L'industriel doit rechercher la version 1.107 dans ses SBOM, ses fichiers de verrouillage et ses images, et révoquer les identifiants exposés. Des dépendances épinglées par empreinte auraient bloqué l'installation de la version piégée.

eMudhra : huit autorités de certification intermédiaires compromises

Autorités de certification eMudhra : les clés privées de huit autorités intermédiaires ont été compromises ; les logiciels qui livrent leur propre magasin de certificats, dont les binaires Go et les programmes Python qui utilisent certifi, doivent être reconstruits ou mis à jour.

Selon la page du signalement, ces autorités chaînent vers des racines reconnues par Mozilla, Microsoft, Apple et Chrome. Beaucoup de clients hors navigateurs n'exigent pas la transparence des certificats, et l'on ignore si la faille a été exploitée contre eux.

Les correctifs se succèdent : Go 1.27.3, publié le 19 octobre, corrige le paquet crypto/x509, mais un programme n'en bénéficie qu'une fois recompilé ; les distributions Linux mettent à jour leur paquet ca-certificates.

L'industriel doit recenser, à partir de ses SBOM, les magasins de certificats et les chaînes de compilation Go de ses produits, puis reconstruire et livrer des mises à jour. Un équipement non corrigé pourrait accepter un faux certificat sans que personne ne s'en aperçoive.

CLI d'OVHcloud : l'éditeur publie la cause du piégeage

Mise à jour, CLI d'OVHcloud : selon l'avis publié le 20 octobre 2026 par OVHcloud, environ 250 téléchargements des versions piégées ont eu lieu, et le dépôt n'imposait pas l'immuabilité des versions publiées ; la cause initiale est une extension VS Code malveillante installée sur l'ordinateur personnel d'un contributeur.

Selon The Hacker News, la substitution a été repérée par la chaîne d'intégration d'un client, qui vérifiait l'empreinte

SHA-256 de l'archive et s'est mise à échouer. Le réglage d'immuabilité des versions, généralement disponible sur GitHub depuis octobre 2025, verrouille les fichiers et l'étiquette d'une version, mais ne protège que les versions créées après son activation.

L'industriel peut vérifier que ses chaînes d'intégration contrôlent l'empreinte des outils téléchargés, et que ses propres dépôts imposent l'immuabilité des versions publiées. Il pourrait aussi demander ces garanties à ses fournisseurs.

OpenSSF : un guide pour trouver et corriger les vulnérabilités avec l'IA

Vulnérabilités et IA : l'OpenSSF a publié le 20 octobre 2026 un guide gratuit, *Finding and Fixing Software Vulnerabilities Using AI*, qui recommande notamment de séparer la détection de la validation et de ne jamais intégrer un correctif produit par l'IA sans tests automatisés ni revue humaine.

Le guide parcourt tout le processus : choix des approches, préparation de l'IA et de son bac à sable, détection, validation, tri, correction, vérification, publication, puis prévention.

Quatre recommandations ressortent : séparer l'étape qui détecte de celle qui confirme, faute de quoi l'IA tend à écarter de vraies failles ; lancer l'IA plusieurs fois, ses résultats variant d'une exécution à l'autre ; l'exécuter dans un bac à sable, avec une validation humaine des actions risquées ; transformer chaque faille corrigée en test de non-régression. Les équipes de développement peuvent comparer leurs pratiques à cette liste. L'afflux de signalements produits par l'IA pourrait multiplier les correctifs à intégrer dans les composants open source des produits.

CISA 2030 : la sécurité logicielle parmi les objectifs de l'agence américaine

Stratégie de la CISA : présentée le 26 octobre 2026, la stratégie *CISA 2030* fait de la sécurité logicielle un objectif et annonce des recommandations fondées sur des données pour la sécurité des logiciels et la transparence de la chaîne d'approvisionnement ; un plan de mise en œuvre est prévu sous 180 jours.

Selon le document, la défense des systèmes les plus critiques des États-Unis dépend de logiciels sûrs, capables de résister à une compromission et de se rétablir rapidement. L'agence prévoit de commencer sous 60 jours la revue de ses services.

La stratégie ne crée aucune obligation pour les produits. Les recommandations annoncées pourraient toutefois nourrir les exigences des clients américains envers leurs fournisseurs de logiciels.

EN BREF

Attaque du 11 mai 2026 : 404 versions malveillantes de paquets npm et PyPI, dont TanStack et Mistral AI.

GhostAction : la campagne de vol d'identifiants vise plus de 30 000 dépôts de 3 000 utilisateurs et organisations, après la compromission d'environ 1 900 comptes GitHub.

COMMERCE INTERNATIONAL — Exportations et sanctions

Le Royaume-Uni annonce pour décembre la mise à jour de ses listes de contrôle ; les dossiers ITAR, CMMC et sanctions restent ouverts.

Royaume-Uni : mise à jour des listes de contrôle militaires et dual-use annoncée pour décembre

Royaume-Uni, listes de contrôle : selon l'avis aux exportateurs 2026/24 du 23 octobre 2026, la mise à jour des contrôles sur les biens, logiciels et technologies militaires et *dual-use*, qui reprend les décisions 2025 des régimes multilatéraux, dont l'Arrangement de Wassenaar, devrait entrer en vigueur début décembre.

Les règlements devraient être déposés au Parlement en novembre, sous réserve de l'approbation ministérielle et parlementaire. Ils mettraient à jour la liste militaire, annexée à l'*Export Control Order 2008*, et la liste *dual-use* du règlement européen conservé en droit britannique, ainsi que les contrôles sur les équipements de fabrication de semi-conducteurs, le calcul avancé et les matériaux spécialisés.

L'avis ne précise pas les rubriques modifiées : l'ECJU annonce des informations complémentaires et la publication des règlements sur legislation.gov.uk. Une filiale ou un site britannique doit suivre ces textes pour revoir ses classements.

EN BREF

Royaume-Uni, classement : le service CLC de l'ECJU, suspendu depuis le 12 octobre 2026, doit faire un point d'avancement avant la fin de l'année.

CMMC : la suspension de la phase 2, décidée le 13 juillet 2026, reste sans date de reprise ; NIST SP 800-171 et DFARS 252.204-7012 restent applicables.

FRANCE ET UE — NIS2, IA, défense

Le Conseil arrête sa position sur la déclaration des incidents du Digital Omnibus ; la loi Résilience attend toujours une date d'examen.

Digital Omnibus : le Conseil préfère des points d'entrée nationaux pour déclarer les incidents

Digital Omnibus, déclaration des incidents : le 21 octobre 2026, le Conseil a arrêté sa position de négociation ; plutôt qu'un point d'entrée unique pour toute l'UE, il retient un point d'entrée national dans chaque État membre pour les incidents à déclarer au titre de plusieurs textes européens.

La Commission avait présenté sa proposition le 19 novembre 2025. Le point d'entrée unique qu'elle prévoyait devait être développé par l'ENISA et pouvait s'appuyer sur la plateforme de déclaration du CRA ; la déclaration des incidents par ce point devait devenir obligatoire 18 mois après l'entrée en vigueur du règlement.

Le Conseil demande aussi un point d'information européen sur la déclaration des incidents et des modalités de notification plus harmonisées, y compris pour les incidents transfrontières. Au Parlement européen, les commissions ITRE et LIBE n'ont pas encore voté ; selon l'analyse de nicfab.eu, ce vote est attendu début 2027, et les négociations entre les institutions ne commenceront qu'ensuite.

Rien ne change pour l'instant pour l'industriel : les délais de notification de NIS2 restent en vigueur. Si la position du Conseil l'emporte, une entreprise présente dans plusieurs États membres pourrait devoir déclarer ses incidents auprès de plusieurs guichets nationaux.

EN BREF

Loi Résilience : la conférence des présidents du 20 octobre 2026 n'a pas réinscrit le projet de loi transposant NIS2 ; la suivante se réunit le 27 octobre.

Omnibus défense : le Parlement européen a adopté le 16 septembre 2026 la directive sur les transferts intra-UE de produits de défense, avec de nouvelles licences générales de transfert.

LICENCES OPEN SOURCE ET LOGICIELS EMBARQUÉS

Oracle publie la première mise à jour de JDK 21 sous licence OTN, qui ne permet pas la redistribution ; les contentieux Vizio et Bambu Lab restent ouverts.

Oracle JDK 21.0.13 : première mise à jour sous licence OTN

Mise à jour, Oracle JDK 21 : publiée le 20 octobre 2026, la version 21.0.13 est la première mise à jour de JDK 21 proposée sous licence OTN ; selon la foire aux questions d'Oracle, cette licence ne permet pas la redistribution.

La foire aux questions d'Oracle range les versions d'Oracle JDK 21 publiées après septembre 2026 sous cette licence, réservée aux usages personnels, de développement et assimilés ; l'usage en production relève du support payant d'Oracle.

L'interdiction de redistribuer pèse directement sur un industriel qui livre Java dans ses équipements : il ne peut intégrer la version 21.0.13 ou une version ultérieure sans contrat avec Oracle. Il doit vérifier, dans ses SBOM et dans ceux de ses fournisseurs, quel environnement Java est embarqué. Un fournisseur de sous-ensemble qui applique le dernier correctif pourrait faire entrer, sans le dire, le produit final dans le champ de cette licence.

EN BREF

GPL, SFC contre Vizio : le procès est indiqué par la SFC pour fin 2026 ; aucun verdict n'a été relevé dans les sources consultées.

AGPLv3 : la SFC a publié le 18 mai 2026 sa réponse aux violations de l'AGPLv3 par Bambu Lab ; l'enquête est en cours.

GLOSSAIRE Sigles et termes cités

AI Act Règlement européen 2024/1689

Anchore Éditeur d'une plateforme de sécurité de la chaîne logicielle fondée sur les SBOM

BSI Bundesamt für Sicherheit in der Informationstechnik

cdxgen Outil open source du projet CycloneDX qui génère des SBOM pour de nombreux langages et peut fonctionner comme service HTTP.

CERT-EU Service de cybersécurité des institutions, organes et agences de l'Union européenne.

CERT-FR Centre gouvernemental de veille, d'alerte et de réponse aux attaques informatiques, rattaché à l'ANSSI.

Chainguard Éditeur d'images de conteneurs et de bibliothèques open source sans vulnérabilité connue

CISA Agence américaine de cybersécurité et de sécurité des infrastructures

CLC Control List Classification

CLI Command-Line Interface

CMMC Cybersecurity Maturity Model Certification

CRA Cyber Resilience Act

CSIRT Équipe nationale de réponse aux incidents de sécurité informatique

CVE Common Vulnerabilities and Exposures

CycloneDX Standard de nomenclature des composants (BOM)

DFARS 252.204-7012 Clause du règlement d'acquisition de la Défense américaine imposant la protection des informations non classifiées et la déclaration des incidents cyber

Digital Omnibus Ensemble de propositions de la Commission de novembre 2025 visant à simplifier les règles numériques de l'UE

Directive (UE) 2024/2853 Directive sur la responsabilité du fait des produits défectueux

ECJU Export Control Joint Unit

eMudhra Autorité de certification indienne qui délivre des certificats TLS et de signature, dont des autorités intermédiaires reconnues par les navigateurs.

ENISA Agence de l'Union européenne pour la cybersécurité

ETSI Institut européen des normes de télécommunications

GitHub Plateforme collaborative de développement logiciel

GPL GNU General Public License

Grype Scanneur open source de vulnérabilités

HBOM Hardware Bill of Materials : nomenclature des composants matériels d'un produit.

ITAR International Traffic in Arms Regulations

JDK Java Development Kit

LiteLLM Bibliothèque Python open source et passerelle qui donnent accès à de nombreux modèles d'IA par une interface commune.

Mistral AI Entreprise française d'intelligence artificielle

NIS2 Directive européenne fixant des exigences unifiées de cybersécurité et de notification d'incidents

NIST Institut national américain des normes et de la technologie

NIST SP 800-171 Publication du NIST qui fixe les exigences de sécurité

OpenSSF Communauté de développeurs et d'ingénieurs sécurité

ORT OSS Review Toolkit

OTN Oracle Technology Network License Agreement for Java SE

OWASP Fondation à but non lucratif produisant des projets libres de sécurité applicative (Top 10

OWASP Dependency-Track Plateforme open source d'inventaire de composants et de détection de vulnérabilités à partir de SBOM

PHP Langage de programmation très utilisé

PyPI Python Package Index

SBOM Software Bill of Materials

SCANOSS Outil et service de détection de composants open source et de leurs licences par comparaison d'empreintes de code.

SFC Software Freedom Conservancy

SHA-256 Fonction de hachage cryptographique

SPDX System Package Data Exchange

TanStack Ensemble de bibliothèques JavaScript open source

TR-03183 Directive technique du BSI allemand sur les exigences de cybersécurité du CRA

UTC Temps universel coordonné

VS Code Visual Studio Code

AGENDA Dates à surveiller

10 NOV. — EXPORT ÉTATS-UNIS
Réimposition automatique de la règle des affiliés du BIS, sauf prolongation

NOV. 2026 — EXPORT UE
Règlement délégué adopté le 14 septembre 2026 ; publication au JO après deux mois d'examen du Parlement européen et du Conseil, sauf objection

30 NOV. — EXPORT ÉTATS-UNIS
Projet publié le 1er octobre 2026 : retrait de certains articles de la liste, définitions révisées, nouvelle exemption de licence

DÉC. 2026 — EXPORT ROYAUME-UNI
Mise à jour des listes militaire et dual-use (biens, logiciels, technologies) annoncée par l'avis aux exportateurs 2026/24

9 DÉC. — RESPONSABILITÉ PRODUIT
Transposition de la directive (UE) 2024/2853, qui inclut le logiciel ; elle s'applique aux produits mis sur le marché à partir de cette date

11 DÉC. — CRA
Nombre suffisant d'organismes d'évaluation de la conformité attendu dans les États membres (CRA)

DÉC. 2027 — AI ACT
Règles sur les systèmes d'IA à haut risque de l'annexe III, reportées à cette date par le règlement (UE) 2026/1744

DÉC. 2027 — CRA
Application complète du CRA ; selon l'ENISA, les gestionnaires de logiciels open source sont soumis à la déclaration à la même date

Software Compliance
Revue de presse hebdomadaire, N° 4 du 27 octobre 2026.
Rédigée par une intelligence artificielle (Claude Opus 5.5), peut comporter des erreurs : pensez à croiser vos sources.
Édition en ligne avec sources : revue.dejeun.es/2026-10-27
© 2026 Rodolphe Dejeunes, publié sous licence CC BY 4.0.